

Course Introduction

CS 466

Adam O'Neill

Class Logistics

Instructor: [Adam O'Neill](mailto:adamo@cs.umass.edu), adamo@cs.umass.edu, LGRC 329A

TA: Carter Luck, cluck@umss.edu

UCA: Meenakshi Iyer, meenakshiiye@umass.edu

Office Hours: TBD. Fill out the when2meet poll on Piazza!

Where to get all information: *Piazza*

Where to submit assignments: *Gradescope*

Grading: 10% quizzes, 40% take-home assignments, 20% midterm, 30% final. You can do take-home assignments **in partners**.

What is cryptography?

The Story of Art

There is no such thing as **Art**, really.

There are only **ARTISTS**.

The Story of Art
E. H. Gombrich

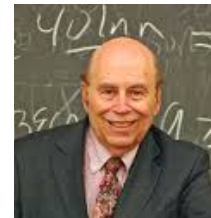


How many can you name?

The Story of Cryptography

There is no such thing as **Cryptography**, really.

There are only **CRYPTOGRAPHERS**.



How many can you name?

Early History

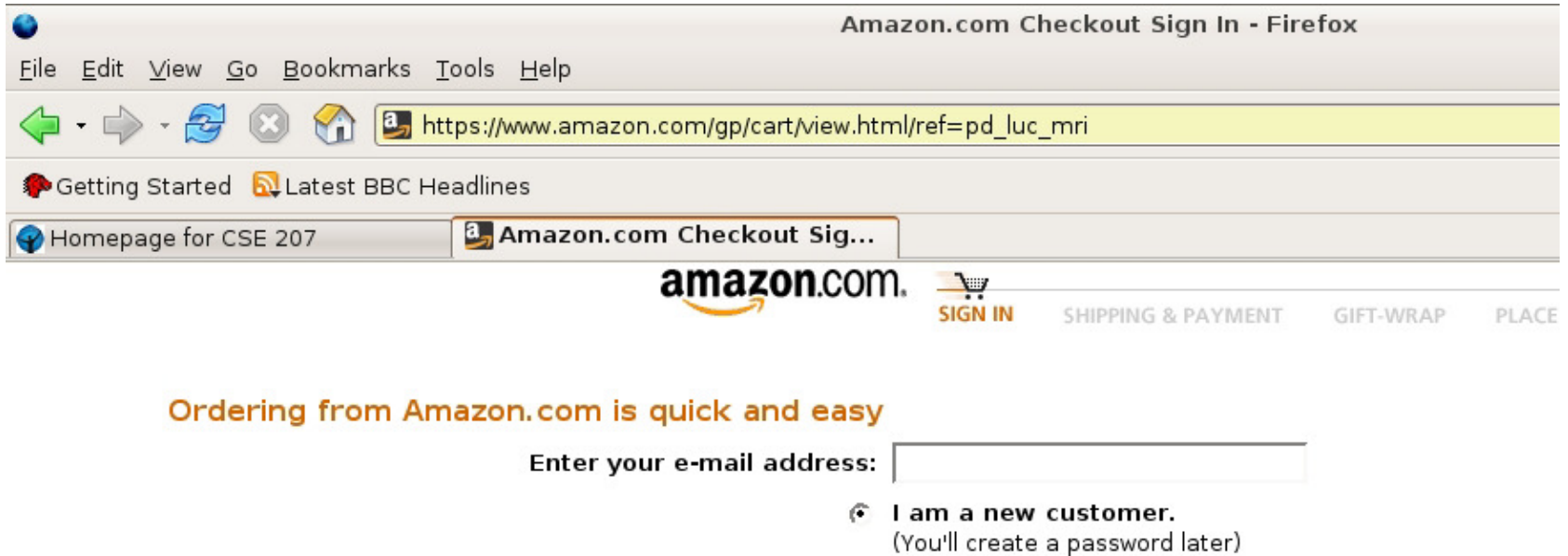
1900 BC, Egypt



1500 BC, Mesopotamia



Usage Today



The screenshot shows a Firefox browser window titled "Amazon.com Checkout Sign In - Firefox". The address bar displays the URL "https://www.amazon.com/gp/cart/view.html/ref=pd_luc_mri". The browser's menu bar includes File, Edit, View, Go, Bookmarks, Tools, and Help. The page content features the Amazon logo, a "SIGN IN" button, and links for "SHIPPING & PAYMENT", "GIFT-WRAP", and "PLACE". Below the navigation bar, a message states "Ordering from Amazon.com is quick and easy". A form prompts the user to "Enter your e-mail address:" with an adjacent text input field. A radio button is selected for the option "I am a new customer. (You'll create a password later)".

Amazon.com Checkout Sign In - Firefox

File Edit View Go Bookmarks Tools Help

https://www.amazon.com/gp/cart/view.html/ref=pd_luc_mri

Getting Started Latest BBC Headlines

Homepage for CSE 207 Amazon.com Checkout Sig...

amazon.com. SIGN IN SHIPPING & PAYMENT GIFT-WRAP PLACE

Ordering from Amazon.com is quick and easy

Enter your e-mail address:

☒ I am a new customer.
(You'll create a password later)

- https invokes the TLS protocol
- TLS uses cryptography
- TLS is in ubiquitous use for secure communication: shopping, banking, Netflix, gmail, Facebook, ...

Usage Today

Other uses of cryptography:

- ATM machines
- Bitcoin
- Messaging apps: whatsapp, viber, line, telegraph, goldbug, chatsecure, ...
- Google authenticator
- ...

11,748 android apps use cryptography (encryption), and 10,327 get it wrong [EBFK13]

Why privacy matters

Glenn Greenwald



If you have something that you don't want anyone to know, maybe you shouldn't be doing it in the first place.

If you have nothing to hide then give me the passwords to ALL your email accounts, your text and chat histories, ...

<https://www.youtube.com/watch?v=pcSlowAhvUk>

20 minute video of TED talk



Eric Schmidt, CEO
Google, 2009

The Chronicle of Higher Education

Why privacy matters even if you have nothing to hide

<http://chronicle.com/article/Why-Privacy-Matters-Even-if/127461/>

Bruce Schneier The Value of Privacy

Privacy protects us from abuses by those in power ... We keep private journals, sing in the shower ... privacy is a basic human need.

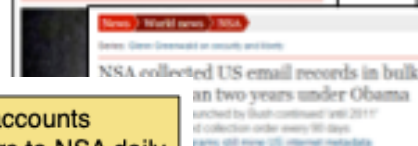
https://www.schneier.com/blog/archives/2006/05/the_value_of_pr.html

<http://zeroknowledgeprivacy.org/library/why-privacy-matters/>

Snowden revelations



Court-approved NSA access to Google and Yahoo accounts
Verizon hands phone records of millions of customers to NSA daily
Extensive wiretapping, tapping undersea cables
Harvesting of millions of email and instant-messaging contact lists
Tracking and mapping location of cellphones
Backdoor planted in Dual_EC_DRBG random-number generator
Paying corporations to adopt NSA-broken standards
Sophisticated malware



The internet metadata collection program was initiated in 2001 for operational and resource reasons. Photograph: Pablo Barrios/Reuters

The Obama administration for more than two years permitted the National Security Agency to continue collecting vast amounts of records detailing the email and internet usage of Americans, according to secret documents obtained by the Guardian.

The documents indicate that under the program, launched in 2001, a federal judge sitting on the secret surveillance panel called the FISA court would approve a bulk collection order for internet metadata "every 90 days". A senior administration official confirmed the program, stating that it ended in 2011.



Prism worked with intelligence agencies but was to allow Prism to collect video and audio conversations. Photograph: Patrick Sotomayor

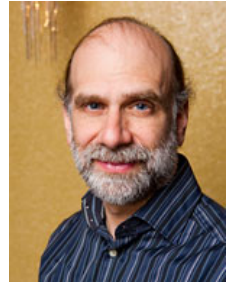
Microsoft has collaborated closely with US intelligence services to allow users' communications to be intercepted, according to the National Security Agency to circumvent the company's own encryption, according to top-secret documents obtained by the Guardian.



Through covert partnerships with tech companies, the spy agencies have inserted secret weaknesses into encryption software. Photograph: Apple/Reuters

Data and Goliath: The Hidden Battles to Collect Your Data and Control Your World

Bruce Schneier



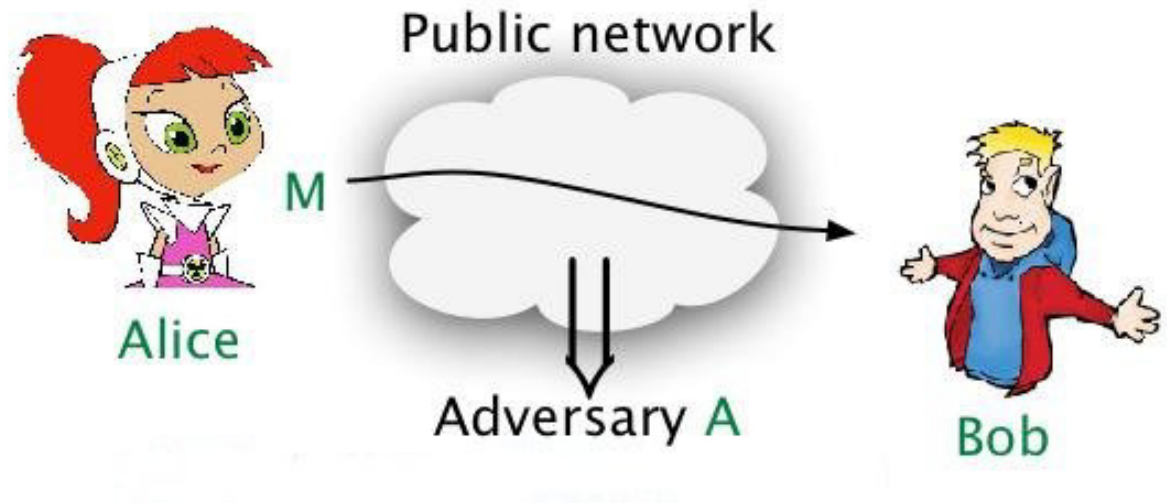
You are under surveillance right now.

Your cell phone provider tracks your location and knows who's with you. Your online and in-store purchasing patterns are recorded, and reveal if you're unemployed, sick, or pregnant. Your e-mails and texts expose your intimate and casual friends. Google knows what you are thinking because it saves your private searches. Facebook can determine your sexual orientation without your ever mentioning it.

The powers that surveil us do more than simply store this information. Corporations use surveillance to manipulate not only the news articles and advertisements we each see, but also the prices we're offered. Governments use surveillance to discriminate, censor, chill free speech, and put people in danger worldwide. And both sides share this information with each other or, even worse, lose it to cybercriminals in huge data breaches.

Much of this is voluntary: we cooperate with corporate surveillance because it promises us convenience, and we submit to government surveillance because it promises us protection. The result is a mass surveillance society of our own making. But have we given up more than we have gained?

Basic Task: Secure Channels



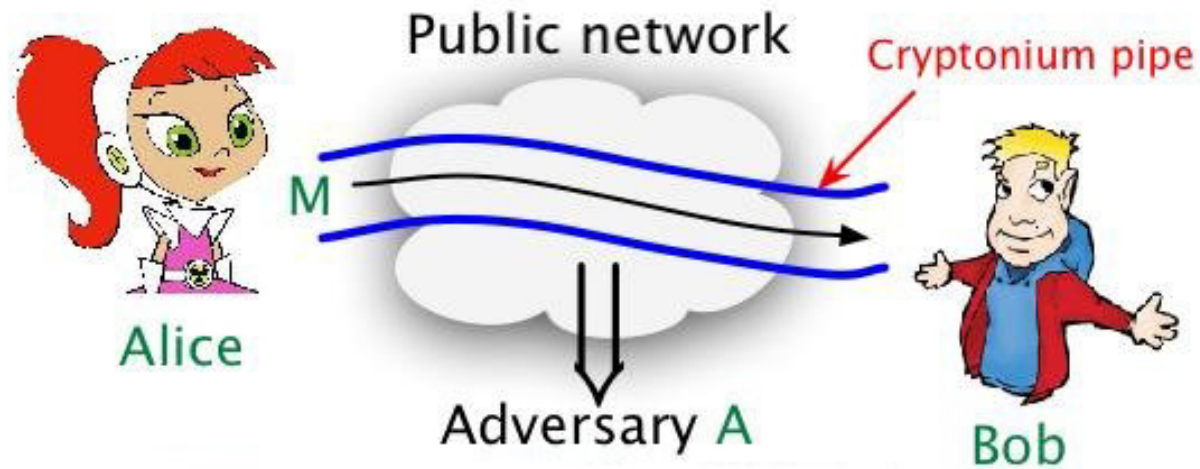
Adversary: clever person with powerful computer

Desired Properties

Privacy: Eve doesn't learn anything about the message.

Integrity/authenticity: Bob is assured the message really came from Alice and was not modified in transit.

Ideal World



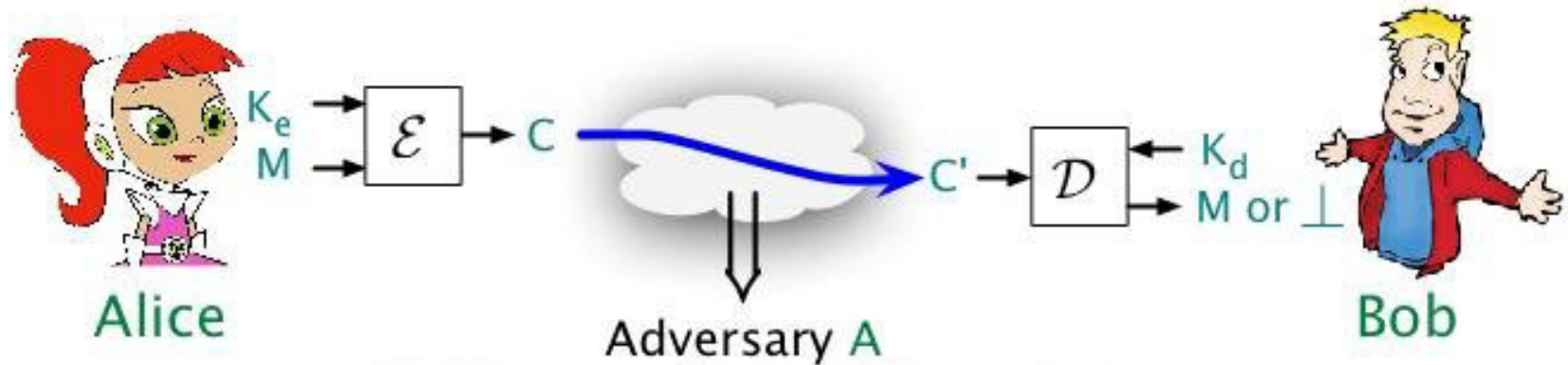
Cryptonium pipe: Cannot see inside or alter content.

All our goals would be achieved!

But cryptonium is only available on **planet Crypton** and is in **short supply**.



Real World



$\mathcal{E}$: encryption algorithm

K_e : encryption key

$\mathcal{D}$: decryption algorithm

K_d : decryption key

Algorithms: standardized, implemented, public!

Correctness: Encrypting any message under any key and decrypting the resulting ciphertext under the matching key results in the same message.

Main Concerns

How to define security goals?

How to design cryptographic schemes?

How to gain confidence that our schemes achieve our goals?

Substitution Ciphers

Substitution ciphers/Caesar ciphers:

$K_e = K_d = \pi: \Sigma \rightarrow \Sigma$, a secret permutation

e.g., $\Sigma = \{A, B, C, \dots\}$ and π is as follows:

σ	A	B	C	D	$\dots$
$\pi(\sigma)$	E	A	Z	U	$\dots$

$$\begin{aligned}\mathcal{E}_\pi(CAB) &= \pi(C)\pi(A)\pi(B) \\ &= Z \ E \ A\end{aligned}$$

$$\begin{aligned}\mathcal{D}_\pi(ZEA) &= \pi^{-1}(Z)\pi^{-1}(E)\pi^{-1}(A) \\ &= C \ A \ B\end{aligned}$$

Substitution Ciphers

Algorithm $\mathcal{E}_\pi(M)$

For $i = 1, \dots, |M|$ do

$C[i] \leftarrow \pi(M[i])$

Return C

Algorithm $\mathcal{D}_\pi(C)$

For $i = 1, \dots, |C|$ do

$M[i] \leftarrow \pi^{-1}(C[i])$

Return M

A message M is a string over an underlying **alphabet**

A key π specifies a **permutation** on the **alphabet**

We assume the scheme is **punctuation-respecting**

Frequency Analysis

Suppose adversary has ciphertext:

COXBX TBX CVK CDGXR DI T GTI'R ADHX VOXI OX ROKQAU
IKC RNXPQATCX: VOXI OX PTI'C THHKBU DC, TIU VOXI OX
PTI.

Frequency Analysis

^E ^E ^E ^E , ^E ^E ^E
 COXBX TBX CVK CDGXR DI T GTI'R ADHX VOXI OX ROKQAU
^E ^E: ^E ^E , ^E
 IKC RNXPQATCX: VOXI OX PTI'C THKBU DC', TIU VOXI
^E
 OX PTI.

A	B	C	D	E	F	G	H	I	J	K	L	M
3	3	7	4	0	0	2	3	9	0	4	0	0

N	O	P	Q	R	S	T	U	V	W	X	Y	Z
1	8	3	2	4	0	8	3	4	0	13	0	0

Frequency Analysis

^E ^E ^E ^E ^E ^E ^E ^E ^E
 COXBX TBX CVK CDGXR DI T GTI'R ADHX VOXI OX ROKQAU
^E ^E ^E ^E ^E ^E ^E ^E
 IKC RNXPQATCX: VOXI OX PTI'C THKBU DC', TIU VOXI
^E
 OX PTI.

OX in ciphertext $\Rightarrow \pi^{-1}(O) \in \{B, H, M, W\}$

Guess $\pi^{-1}(O) = H$ since O has pretty high frequency

^HE^E
COXBX

Could be: THERE, THESE, WHERE, ...

Guess $\pi^{-1}(C) = T$ since there is no ? in ciphertext so WHERE is unlikely.

Frequency Analysis

THE E E T T E , E HE HE H
 COXBX TBX CVK CDGXR DI T GTI'R ADHX VOXI OX ROKQAU
 T E TE: HE HE 'T T, HE
 IKC RNX PQATCX: VOXI OX PTI'C THKBU DC, TIU VOXI
 HE
 OX PTI.

T is a single-letter word so $\pi^{-1}(T) \in \{A, I\}$

We know $\pi^{-1}(B) \in \{R, S\}$

So TBX could be: ARE, ASE, IRE, ISE

We guess ARE

Frequency Analysis

THERE ARE T T E A A ' E HE HE H
COXBX TBX CVK CDGXR DI T GTI'R ADHX VOXI OX ROKQAU

T E ATE: HE HE A 'T A R T, A HE
IKC RNXPQATCX: VOXI OX PTI'C THHKBU DC, TIU VOXI

HE A .
OX PTI.

*T
DC

D must be: A or I but T is A so D is I.

Frequency Analysis

THERE ARE TWO TIMES IN A MAN'S LIFE WHEN HE SHOULD
COXBX TBX CVK CDGXR DI T GTI'R ADHX VOXI OX ROKQAU

NOT SPECULATE: WHEN HE CAN'T AFFORD IT, AND WHEN
IKC RNXPQATCX: VOXI OX PTI'C THHKBU DC, TIU VOXI

HE CAN.
OX PTI.

Who said it?

Another Example

Example 1 (Cryptography). Stanford's Statistics Department has a drop-in consulting service. One day, a psychologist from the state prison system showed up with a collection of coded messages. Figure 1 shows part of a typical example.

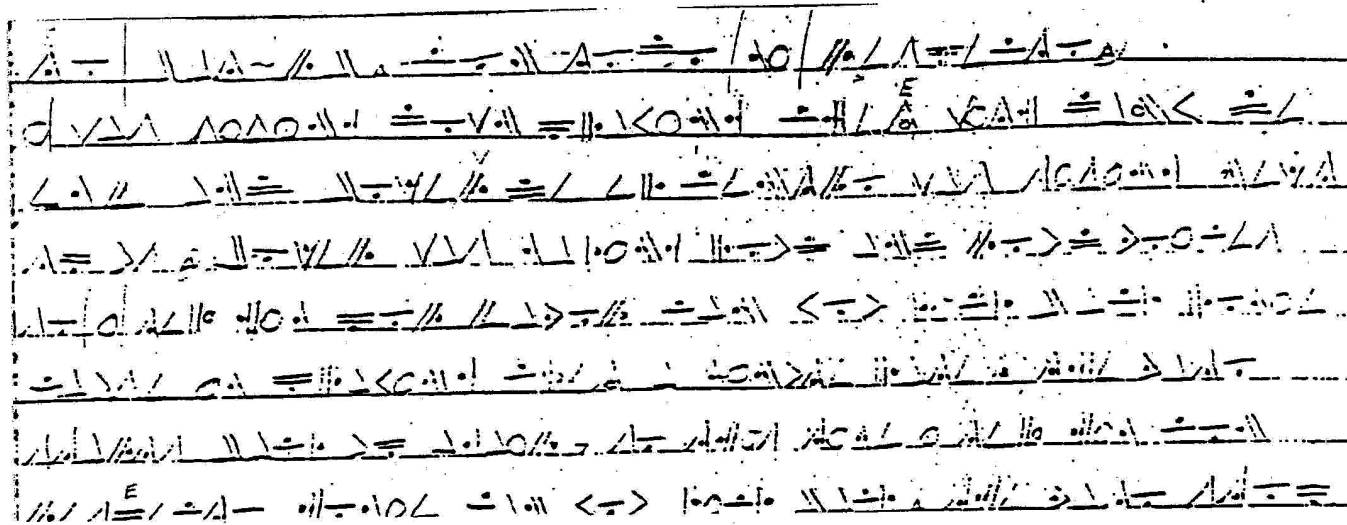


Figure 1

Plausibility Matrices

Let f : Observed Symbols $\rightarrow$ Usual Alphabet

To get the statistics, Marc downloaded a standard text (e.g., *War and Peace*) and recorded the first-order transitions: the proportion of consecutive text symbols from x to y . This gives a matrix $M(x, y)$ of transitions. One may then associate a plausibility to f via

$$\text{Pl}(f) = \prod_i M(f(s_i), f(s_{i+1}))$$

Metropolis Algorithm

- Start with a preliminary guess, say f .
- Compute $P(f)$.
- Change to f_* by making a random transposition of the values f assigns to two symbols.
- Compute $P(f_*)$; if this is larger than $P(f)$, accept f_* .
- If not, flip a $P(f_*)/P(f)$ coin; if it comes up heads, accept f_* .
- If the coin toss comes up tails, stay at f .

Converges rapidly!

Result

to bat-rb. con todo mi respeto. i was sitting down playing chess with danny de emf and boxer de el centro was sitting next to us. boxer was making loud and loud voices so i tell him por favor can you kick back homie cause im playing chess a minute later the vato starts back up again so this time i tell him con respecto homie can you kick back. the vato stop for a minute and he starts up again so i tell him check this out shut the f**k up cause im tired of your voice and if you got a problem with it we can go to celda and handle it. i really felt disrespected thats why i told him. anyways after i tell him that the next thing I know that vato slashes me and leaves. dy the time i figure im hit i try to get away but the c.o. is walking in my direction and he gets me right dy a celda. so i go to the hole. when im in the hole my home boys hit doxer so now "b" is also in the hole. while im in the hole im getting schoold wrong and

Shannon's One-Time Pad

$$K_e = K_d = \underbrace{K \xleftarrow{\$} \{0, 1\}^k}_{\substack{K \text{ chosen at random} \\ \text{from } \{0, 1\}^k}}$$

For any $M \in \{0, 1\}^k$

$$- \mathcal{E}_K(M) = K \oplus M$$

$$- \mathcal{D}_K(C) = K \oplus C$$



Perfect Security

Theorem (Shannon): OTP is perfectly secure as long as only one message encrypted.

“Perfect” secrecy, a notion Shannon defines, captures mathematical impossibility of breaking an encryption scheme.

Fact: if $|M| > |K|$, then no scheme is perfectly secure.

Modern Cryptography: A Computational Science

Security of a “practical” system must rely not on the impossibility but on the computational difficulty of breaking the system.

(“Practical” = more message bits than key bits)

Rather than:

“It is impossible to break the scheme”

We might be able to say:

“No attack using $\leq 2^{160}$ time succeeds with probability $\geq 2^{-20}$ ”

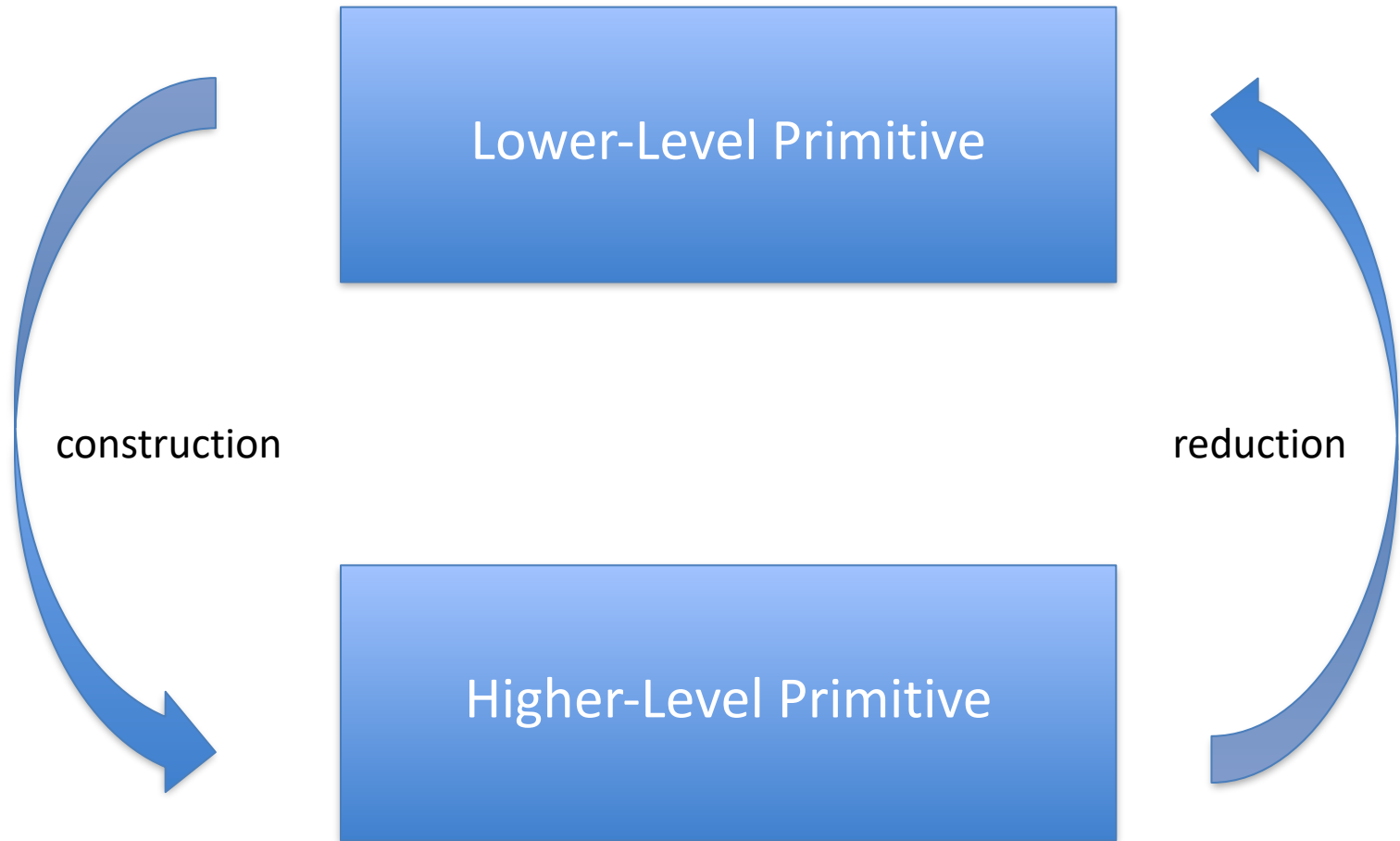
I.e., Attacks can exist as long as cost to mount them is prohibitive, where
Cost = computing time/memory, \$\$\$

Modern Cryptography: A Computational Science

Cryptography uses

- Number theory
- Combinatorics
- Modern algebra
- Probability theory

Provable Security



Lower-Level Primitives

Examples:

- **Factoring:** Given large $N = pq$, find p, q
- **Block cipher primitives:** DES, AES, ...
- **Hash functions:** MD5, SHA1, SHA3, ...

Features:

- Few such primitives
- Design an art, confidence by history.

Drawback: Don't directly solve any security problem.

Higher-Level Primitives

Goal: Solve security problem of **direct** interest.

Examples: encryption, authentication, digital signatures, key distribution,
...

Features:

- **Lots of them**

Defining Security

A great deal of design tries to produce schemes without first asking:

“What exactly is the security goal?”

This leads to schemes that are complex, unclear, and wrong.

Being able to precisely state what is the security goal of a design is challenging but important.

We will spend a lot of time developing and justifying strong, precise notions of security.

Thinking in terms of these precise goals and understanding the need for them may be the most important thing you get from this course!

Practical Adoption

Schemes designed via the principles we will study are in use ([TLS](#), [SSH](#), [IPSec](#), ...): HMAC, RSA-OAEP, ECIES, Ed25519, CMAC, GCM, ...

What To Get From This Course

Be able to

- Identify threats
- Evaluate security solutions and technologies
- Design high-quality solutions
- Develop next-generation privacy tools
- ...

If nothing else, develop a healthy sense of paranoia!